d) las copias de seguridad (véase 8.13) y la capacidad de recuperación;

e) los requisitos de programación, incluidas las interdependencias con otros sistemas;

f) instrucciones para el tratamiento de errores u otras condiciones excepcionales [por ejemplo, restricciones en el uso de programas de utilidades (véase 8.18)], que puedan surgir durante la ejecución del trabajo;

g) contactos de soporte y escalado, incluidos los contactos de soporte externo en caso de dificultades operativas o técnicas inesperadas;

h) instrucciones de manipulación de los soportes de almacenamiento (véanse 7.10 y 7.14);

i) procedimientos de reinicio y recuperación del sistema en caso de fallo de este;

j) la gestión de pistas de auditoría y de la información de registro del sistema (véanse 8.15 y 8.17) y los sistemas de monitorización por vídeo (véase 7.4);

k) procedimientos de monitorización tales como capacidad, rendimiento y seguridad (véanse 8.6 y 8.16);

l) instrucciones de mantenimiento.

La documentación sobre los procedimientos operacionales debería revisarse y actualizarse cuando sea necesario, y sus modificaciones deberían ser autorizadas. Y cuando sea técnicamente factible, los sistemas de información deberían gestionarse de forma coherente, utilizando los mismos procedimientos, herramientas y recursos.

Información adicional

Ninguna información adicional.

6 Controles de personas

6.1 Comprobación

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobernanza_y_Ecosistema

Control

La comprobación de los antecedentes de todos los candidatos al puesto de trabajo se debería llevar a cabo antes de unirse a la organización y de forma continuada, de acuerdo con las leyes, reglamentos y éticas aplicables, y deberían ser proporcional a los requisitos empresariales, la clasificación de la información a la que accederá y los riesgos percibidos.

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

Propósito

Garantizar que todo el personal es elegible y adecuado para las funciones para las que se le considera y que continúe siéndolo durante su empleo.

Orientación

Se debería realizar un proceso de investigación de antecedentes de todo el personal, tanto a tiempo completo, como a tiempo parcial y temporal. Cuando estas personas sean contratadas a través de proveedores de servicios, los requisitos sobre antecedentes deberían incluirse en los acuerdos contractuales entre la organización y dichos proveedores.

La información sobre todos los candidatos considerados para ocupar puestos en la organización debería ser recopilada y tratada teniendo en cuenta la legislación vigente en la jurisdicción correspondiente. En algunas jurisdicciones, se puede exigir legalmente a la organización que informe de antemano a los candidatos sobre las actividades de comprobación de antecedentes.

La verificación debería tener en consideración toda la legislación aplicable en materia de privacidad, protección de la información personal identificable y relativa a empleo, y cuando esté permitido, deberá incluir lo siguiente:

a) disponibilidad de referencias satisfactorias (por ejemplo, referencias de empresas y personas);

b) verificación del currículum vítae del solicitante (para comprobar que es completo y preciso);

c) confirmación de las cualificaciones académicas y profesionales presentadas;

d) comprobación independiente de la identificación (por ejemplo, pasaporte u otro documento aceptable expedido por las autoridades competentes);

e) una verificación más detallada, como la revisión crediticia o de antecedentes penales si el candidato asume una función crítica.

Cuando se contrata a una persona para un rol específico de seguridad de la información, la organización debería asegurarse de que el candidato:

a) tiene la competencia necesaria para desempeñar el rol de seguridad;

b) se puede confiar en él para asumir dicho perfil, especialmente si éste es crítico para la organización.

Cuando un puesto trabajo, ya sea en el nombramiento inicial o en la promoción, implique que la persona tenga acceso a instalaciones de tratamiento de la información y, en particular, si éstas implican el manejo de información confidencial (por ejemplo, información financiera, información personal o información sanitaria), la organización debería considerar la posibilidad de realizar verificaciones adicionales más detalladas.

Los procedimientos deberían definir los criterios y las limitaciones de las comprobaciones (por ejemplo, quién es elegible para realizar la investigación de antecedentes, y cómo, cuándo y por qué se llevan a cabo las comprobaciones).

En situaciones en las que la verificación no pueda completarse a tiempo, deberán aplicarse controles paliativos hasta que la revisión haya finalizado, por ejemplo:

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

a) retraso en la incorporación;

b) retraso en el despliegue de los activos de la empresa;

c) incorporación con acceso reducido;

d) cese de la relación laboral.

Los controles de verificación deberían repetirse periódicamente para confirmar la idoneidad en todo momento del personal, en función de la importancia de la función de cada persona.

Información adicional

Ninguna información adicional.

6.2 Términos y condiciones de contratación

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobernanza_y_Ecosistema

Control

Los acuerdos contractuales de empleo deberían indicar las responsabilidades del personal y de la organización en materia de seguridad de la información.

Propósito

Garantizar que el personal comprende sus responsabilidades en materia de seguridad de la información para las funciones para las que para las que son considerados.

Orientación

Las obligaciones contractuales del personal deberían tener en consideración la política de seguridad de la información de la organización y las políticas específicas relevantes. Además, pueden aclararse y establecerse los siguientes puntos:

a) el personal al que se le dé acceso a información confidencial debería firmar los acuerdos de confidencialidad o de no revelación de información de manera previa a darle acceso a dicha información y a otros activos asociados (véase 6.6);

b) las responsabilidades y derechos legales [por ejemplo, en relación con la legislación sobre derechos de autor o de protección de datos (véanse 5.32 y 5.34)];

c) las responsabilidades en materia de clasificación de la información y gestión de la información de la organización y de otros activos asociados, instalaciones de tratamiento de información y servicios de información manejados por el personal (véanse 5.9 a 5.13);

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

d) las responsabilidades de las partes interesadas del tratamiento de la información recibida;

e) las acciones que tienen que tomarse si el personal hace caso omiso de los requisitos de seguridad de la organización (véase 6.4).

Los roles y responsabilidades en materia de seguridad de la información deberían comunicarse a los candidatos durante el proceso previo a la contratación.

La organización debería asegurarse de que el personal acepta los términos y las condiciones relativas a la seguridad de la información. Estos términos y condiciones deberían ser apropiados para la naturaleza y el alcance del acceso que tendrán a los activos de la organización asociados con los sistemas y servicios de información. Los términos y condiciones relativos a la seguridad de la información deberán revisarse cuando cambie la legislación, los reglamentos, la política de seguridad de la información o las políticas específicas.

Cuando sea apropiado, las responsabilidades contenidas en los términos y condiciones de empleo deberían continuar durante un determinado periodo de tiempo después de la finalización de contratación (véase 6.5).

Información adicional

Se puede utilizar un código de conducta para establecer las responsabilidades del personal en materia de seguridad de la información en relación con la confidencialidad, la protección de la información personal identificable, la ética, el uso apropiado de la información de la organización y otros activos asociados, así como la buena reputación de la organización.

Se puede requerir a una parte externa, con la que esté asociado el personal proveedor, que celebre acuerdos contractuales en nombre de la persona contratada.

Si la organización no es una persona jurídica y no tiene empleados, el equivalente de acuerdo contractual y de los términos y condiciones pueden considerarse en la línea con las directrices de este control.

6.3 Concienciación, educación y formación en seguridad de la información

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobernanza_y_Ecosistema

Control

El personal de la organización y las partes interesadas pertinentes deberían recibir una adecuada concienciación, educación y formalización sobre la seguridad de la información y actualizaciones periódicas de la política de seguridad de la información de la organización, y de las políticas y los procedimientos específicos, según corresponda a su puesto de trabajo.

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

Propósito

Garantizar que el personal y las partes interesadas relevantes conozcan y cumplan sus responsabilidades en materia de seguridad de la información.

Orientación

General

Debería establecerse un programa de concienciación, educación y capacitación en seguridad de la información de acuerdo con la política de seguridad de la información de la organización, con políticas específicas y con los procedimientos relevantes sobre seguridad de la información, teniendo en cuenta la información de la organización a proteger y los controles de seguridad de la información que se han implementado para proteger dicha información.

La concienciación, educación y capacitación en materia de seguridad de la información deberían tener lugar periódicamente. Una concienciación, educación y capacitación inicial puede ofrecerse al personal nuevo y a los que se trasladan a nuevos puestos o roles con requisitos de seguridad de la información sustancialmente diferentes.

La comprensión del personal debería evaluarse al final de una actividad de concienciación, educación o capacitación, para así comprobar la transferencia de conocimientos y la eficacia del programa específico.

Concienciación

Un programa de concienciación sobre la seguridad de la información debería tener como objetivo que el personal sea consciente de sus responsabilidades en materia de seguridad de la información y de los medios disponibles para cumplirlas.

El programa de concienciación debería planificarse teniendo en cuenta los roles del personal en la organización, incluido tanto el personal interno como externo (por ejemplo, consultores externos, personal de proveedores). Las actividades del programa de concienciación deberían programarse a lo largo del tiempo, preferiblemente con regularidad, de modo que las actividades se repitan y abarquen a nuevo personal. También debería basarse en las lecciones aprendidas de los incidentes de seguridad de la información.

El programa de concienciación debería incluir una serie de actividades de concienciación a través de canales físicos o virtuales adecuados, como campañas, folletos, carteles, boletines, sitios web, sesiones o reuniones informativas, módulos de aprendizaje electrónico y correos electrónicos.

La concienciación sobre la seguridad de la información debería abarcar aspectos generales como:

a) el compromiso de la dirección con la seguridad de la información en toda la organización;

b) las necesidades de familiarización y cumplimiento de las normas y obligaciones aplicables en materia de seguridad de la información, teniendo en cuenta la política de seguridad de la información y otras políticas específicas, normas, legislación, estatutos, reglamentos, contratos y acuerdos;

c) responsabilidad personal por las propias acciones e inacciones, y responsabilidades generales para la seguridad o protección de la información perteneciente a la organización y a las partes interesadas;

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

d) procedimientos básicos de seguridad de la información [por ejemplo, notificación de eventos de seguridad de la información (6.8)] y controles básicos [por ejemplo, seguridad de contraseñas (5.17)];

e) puntos de contacto y recursos para obtener información adicional y asesoramiento sobre materia de seguridad de la información, incluido más material de concienciación sobre seguridad de la información.

Educación y capacitación

La organización debería identificar, preparar e implementar un plan de formación adecuado para los equipos técnicos cuyos roles requieran destrezas y experiencia específicos. Los equipos técnicos deberían tener las habilidades para configurar y mantener el nivel de seguridad requerido para dispositivos, sistemas, aplicaciones y servicios. Si faltan habilidades para ello, la organización debería tomar medidas para que las adquieran.

El programa de educación y capacitación debería considerar distintas formas [por ejemplo, conferencias o autoaprendizaje, formación en el puesto de trabajo a cargo de expertos o consultores, rotación del personal para seguir diferentes actividades, contratación de personal ya cualificado, o subcontratación de consultores]. Puede utilizar diferentes medios de impartición, como la formación presencial, a distancia, a través de Internet, a su propio ritmo, etc. El personal técnico debería mantener al día sus conocimientos suscribiéndose a boletines y revistas o asistiendo a conferencias y eventos destinados a la mejora técnica y profesional.

Información adicional

A la hora de elaborar un programa de concienciación, es importante no sólo centrarse en el "qué" y el "cómo", sino también en el "por qué", siempre que sea posible. Es importante que el personal comprenda el objetivo de la seguridad de la información y sus posibles efectos, positivos y negativos, de su propio comportamiento en la organización.

La concienciación, la educación y la capacitación en materia de seguridad de la información pueden formar parte de otras actividades, o llevarse a cabo en colaboración con ellas, como por ejemplo, en la formación en gestión general de la información, TIC, seguridad o privacidad.

6.4 Proceso disciplinario

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder	#Seguridad_de_los_recursos_humanos	#Gobernanza_y_Ecosistema

Control

Debería existir un proceso disciplinario formal que haya sido comunicado a los empleados y partes interesadas pertinentes, que recoja las acciones a tomar ante aquellos que hayan provocado alguna brecha de seguridad.

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

Propósito

Garantizar que el personal y otras partes interesadas relevantes comprendan las consecuencias de la violación de la política de seguridad de la información, para disuadirlas y para tratarles adecuadamente en caso de cometer infracción.

Orientación

El proceso disciplinario no debería iniciarse sin la verificación previa de que se ha producido una infracción de la política de seguridad de la información (véase 5.28).

El proceso disciplinario formal debería prever una respuesta gradual que tenga en cuenta factores como:

a) la naturaleza (quién, qué, cuándo, cómo) y la gravedad de la infracción y sus consecuencias;

b) si la infracción ha sido intencionada (dolosa) o no intencionada (accidental);

c) si se trata o no de una primera infracción o de una reincidencia;

d) si el infractor recibió o no la formación adecuada.

La respuesta debería tener en consideración los requisitos legales, estatutarios, reglamentarios, contractuales y empresariales relevantes, así como otros factores necesarios. El proceso disciplinario también debería ser disuasorio para evitar que el personal y otras partes interesadas violen la política de seguridad de la información, otras políticas específicas y los procedimientos de seguridad de la información. Las violaciones deliberadas de la política de seguridad de la información pueden requerir medidas inmediatas.

Información adicional

Siempre que sea posible, la identidad de las personas sujetas a medidas disciplinarias debería protegerse de acuerdo con los requisitos aplicables.

Cuando las personas demuestren un comportamiento excelente en relación con la seguridad de la información, podrían ser recompensados para promover la seguridad de la información y fomentar el buen comportamiento.

6.5 Responsabilidades ante la finalización o cambio

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos #Gestión_de_activos	#Gobernanza_y_Ecosistema

Control

Las responsabilidades y obligaciones en seguridad de la información que siguen vigentes después del cese o cambio de empleo se deberían definir, hacer cumplir y comunicar al personal pertinente y a otras partes interesadas.

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

Propósito

Proteger los intereses de la organización como parte del proceso de cambio o terminación de empleo o contratos.

Orientación

El proceso para gestionar la terminación o cambio de empleo debería definir qué responsabilidades y obligaciones sobre seguridad de la información deberían permanecer válidos después de la terminación o cambio. Esto puede incluir la confidencialidad de la información, la propiedad intelectual y otros conocimientos obtenidos, así como responsabilidades contenidas en cualquier otro acuerdo de confidencialidad (véase 6.6). Las responsabilidades y obligaciones que sigan siendo válidas tras la finalización del empleo o del contrato deberían figurar en los términos y condiciones del empleo de la persona (véase 6.2), su contrato o en los acuerdos establecidos. Otros contratos o acuerdos que se prolonguen durante un periodo determinado tras la finalización de la relación laboral también pueden incluir responsabilidades en materia de seguridad de la información.

Los cambios de responsabilidad o de empleo deberían gestionarse como el cese de la responsabilidad o empleo actual combinado con el inicio de la nueva responsabilidad o empleo.

Los roles y responsabilidades en materia de seguridad de la información de cualquier persona que abandone o cambie de puesto de trabajo deberían identificarse y transferirse a otra persona.

Debería establecerse un proceso para la comunicación de los cambios y de los procedimientos operacionales al personal, a otras partes interesadas (por ejemplo, a clientes y proveedores).

El proceso de finalización o cambio de empleo debería aplicarse también al personal externo (es decir, a los proveedores) cuando se produzca una finalización del contrato o del puesto de trabajo de dicho personal con la organización, o cuando se produzca un cambio de puesto de trabajo dentro de la organización.

Información adicional

En muchas organizaciones, el departamento de recursos humanos suele tener la responsabilidad del proceso completo de finalización del contrato, y trabaja conjuntamente con el supervisor que deja su puesto para gestionar los aspectos de seguridad de la información de los procedimientos relevantes. En el caso del personal proporcionado mediante una tercera parte (por ejemplo, a través de un proveedor), este proceso de finalización será gestionado por ésta de acuerdo con el contrato entre la organización y la tercera parte.

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

6.6 Acuerdos de confidencialidad o no divulgación

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo	#Confidencialidad	#Proteger	#Seguridad_de_los_recursos_humanos #Protección_de_la_información #Relación_con_los_proveedores	#Gobernanza_y_Ecosistema

Control

Los acuerdos de confidencialidad o no divulgación que reflejen las necesidades de protección de la información de la organización deberían ser identificados, documentados, revisados regularmente y firmados por el personal y otras partes interesadas relevantes.

Propósito

Mantener la confidencialidad de la información a la que tiene acceso el personal o partes externas.

Orientación

Los acuerdos de confidencialidad o de no revelación deberían cumplir el requisito de proteger la información confidencial utilizando términos legalmente exigibles. Los acuerdos de confidencialidad o no revelación son aplicables tanto a las partes interesadas como al personal de la organización. Basándose en los requisitos de seguridad de la información de una organización, los términos de los acuerdos deberían determinarse teniendo en cuenta el tipo de información que se manejará, su nivel de clasificación, su uso y el acceso permitido por la otra parte. Para identificar los requisitos de los acuerdos de confidencialidad o no revelación, deberían tenerse en cuenta los siguientes elementos:

a) una definición de la información a proteger (por ejemplo, información confidencial);

b) la duración prevista de un acuerdo, incluidos los casos en los que puede ser necesario mantener confidencialidad indefinidamente o hasta que la información pase a ser de dominio público;

c) las acciones necesarias cuando se pone fin a un acuerdo;

d) las responsabilidades y acciones de los firmantes para evitar la divulgación no autorizada de información;

e) la propiedad de la información, los secretos comerciales y la propiedad intelectual, y su relación con la protección de la información confidencial;

f) el uso permitido de la información confidencial y los derechos del firmante a utilizar la información;

g) el derecho a auditar y supervisar las actividades que impliquen información confidencial en circunstancias altamente sensibles;

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

h) el proceso de notificación y aviso de la revelación no autorizada o fuga de información confidencial;

i) los términos en los que la información debería ser devuelta o destruida en la finalización del acuerdo;

j) las acciones para llevar a cabo en caso de incumplimiento del acuerdo.

La organización debería tener en consideración el cumplimiento de los acuerdos de confidencialidad y no revelación para la jurisdicción a la que se aplican (véanse 5.31, 5.32, 5.33, 5.34).

Los requisitos de los acuerdos de confidencialidad y no revelación deberían revisarse periódicamente y cuando se produzcan cambios que influyan en estos requisitos.

Información adicional

Los acuerdos de confidencialidad y no revelación protegen la información de la organización e informan a los firmantes de su responsabilidad de proteger, utilizar y revelar la información de forma responsable y autorizada.

6.7 Teletrabajo

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos #Protección_de_la_información #Seguridad_física #Seguridad_del_Sistema_y_de_la_red	#Protección

Control

Se deberían implementar medidas de seguridad cuando el personal trabaje de forma remota para proteger la información a la que se acceda, procese o almacene fuera de las instalaciones de la organización.

Propósito

Garantizar la seguridad de la información cuando el personal trabaja de manera remota.

Orientación

Desde una ubicación de fuera de los locales de la organización, accediendo a la información ya sea en papel o electrónicamente a través de equipos TIC. Los entornos de trabajo remoto incluyen aquellos relativos a "teletrabajo", "trabajo a distancia", "lugar de trabajo flexible", "entornos de trabajo virtuales" y "mantenimiento a distancia".

NOTA Es posible que no todas las recomendaciones de esta guía puedan aplicarse debido a la legislación local y reglamentos de las distintas jurisdicciones.

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

Las organizaciones que permiten actividades de trabajo de manera remota deberían instrumentar una política específica que defina las condiciones y restricciones sobre el trabajo remoto. Cuando se considere aplicable, se deberían tener en consideración los siguientes aspectos:

a) la seguridad física existente o propuesta del lugar de trabajo de manera remota, teniendo en cuenta la seguridad física del lugar y el entorno local, incluidas las diferentes jurisdicciones en las que se encuentre el personal;

b) normas y mecanismos de seguridad para el entorno físico remoto, tales como archivadores con cerradura, transporte seguro entre ubicaciones y normas para el acceso remoto, escritorio despejado, impresión y eliminación de información y otros activos asociados, y notificación de eventos de seguridad de la información (véase 6.8);

c) los entornos físicos de trabajo de manera remoto previstos;

d) los requisitos de seguridad de las comunicaciones, teniendo en cuenta la necesidad de acceso remoto a los sistemas de la organización, la sensibilidad de la información a la que se va a acceder y transmitir a través del enlace de comunicación, así como la sensibilidad de los sistemas y aplicaciones;

e) el uso de acceso remoto, como el acceso a escritorios virtuales que admiten el procesamiento y almacenamiento de información en equipos de propiedad privada;

f) la amenaza de acceso no autorizado a información o recursos por parte de otras personas que se encuentren en el lugar de trabajo remoto (por ejemplo, familiares y amigos);

g) la amenaza de acceso no autorizado a información o recursos por parte de otras personas en lugares públicos;

h) el uso de redes domésticas y redes públicas, y los requisitos o restricciones sobre la configuración de los servicios de redes inalámbricas;

i) el uso de medidas de seguridad, como cortafuegos y protección contra programas maliciosos;

j) mecanismos seguros para desplegar e inicializar sistemas de manera remota;

k) mecanismos seguros para la autenticación y establecimiento de privilegios de acceso teniendo en cuenta la vulnerabilidad de los mecanismos de autenticación de factor único cuando se permite el acceso remoto a la red de la organización.

Las directrices y medidas a considerar deberían incluir:

a) la provisión de equipos y mobiliario de almacenamiento adecuados para las actividades de trabajo a distancia, cuando no se permite el uso de equipos de propiedad privada que no estén bajo el control de la organización;

b) una definición de los trabajos permitidos, la clasificación de la información que se puede manejar y los sistemas y servicios internos a los que está autorizado a acceder el trabajador a distancia;

c) la provisión de la formación de las personas que trabajan a distancia y de las que les prestan apoyo. Esta formación debería incluir cómo realizar los procesos de negocio de forma segura mientras se trabaja a distancia;

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

d) el suministro de los equipos de comunicación adecuados, incluidos métodos para proteger el acceso remoto, como los requisitos de bloqueo de la pantalla del dispositivo y temporizadores de inactividad; la habilitación del seguimiento de la ubicación del dispositivo; la instalación de funciones de borrado a distancia;

e) seguridad física;

f) normas y directrices sobre el acceso de familiares y visitantes a los equipos y la información;

g) la provisión de soporte y mantenimiento de *hardware* y *software*;

h) la provisión de seguros;

i) los procedimientos de copia de seguridad y continuidad del negocio;

j) la auditoría y la supervisión de la seguridad;

k) la revocación de la autorización y de los derechos de acceso y la devolución del equipo cuando finalicen las actividades de trabajo a distancia.

Información adicional

Ninguna información adicional.

6.8 Notificación de los eventos de seguridad de la información

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Detectivo	#Confidencialidad #Integridad #Disponibilidad	#Detectar	#Gestión_de_eventos_de_seguridad_de_la_información	#Defensa

Control

La organización debería proporcionar un mecanismo para que el personal notifique a tiempo eventos de seguridad de la información observados o sospechosos a través de los canales apropiados.

Propósito

Proporcionar la notificación oportuna, coherente y eficaz de los eventos de seguridad de la información que puedan ser identificados por el personal.

Orientación

Todo el personal y los usuarios deberían ser conscientes de su responsabilidad de notificar los eventos de seguridad de la información lo antes posible para prevenir o minimizar el efecto de los incidentes de seguridad de la información.

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR

También deberían conocer el procedimiento para notificar eventos de seguridad de la información y el punto de contacto al que deberían notificarse. El mecanismo de notificación debería ser lo más fácil, accesible y disponible posible. Los eventos de seguridad de la información incluyen incidentes, brechas y vulnerabilidades.

Las situaciones que deberían tenerse en cuenta para la notificación de eventos de seguridad de la información incluyen:

a) controles de seguridad de la información ineficaces;

b) brechas en las expectativas de confidencialidad, integridad o disponibilidad de la información;

c) errores humanos;

d) incumplimiento de la política de seguridad de la información, otras políticas específicas o normas aplicables;

e) brechas de las medidas de seguridad física;

f) cambios en el sistema que no hayan pasado por el proceso de gestión de cambios;

g) fallos de funcionamiento u otros comportamientos anómalos del *software* o *hardware* del sistema;

h) infracciones de acceso;

i) vulnerabilidades;

j) sospecha de infección por código malicioso.

Se debería aconsejar al personal y a los usuarios que no intenten probar las presuntas vulnerabilidades de la seguridad de la información. Probar vulnerabilidades puede interpretarse como un potencial uso indebido del sistema y también puede causar daños al sistema o al servicio de información, y puede corromper u ocultar pruebas digitales. En última instancia, esto puede dar lugar a responsabilidad legal para la persona que realiza las pruebas.

Información adicional

Para más información, consulte la serie de Normas ISO/IEC 27035.

7 Controles físicos

7.1 Perímetro de seguridad física

Tipo de control	Dimensiones de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física	#Protección

Este documento ha sido adquirido por PEOPLE MEDIA, S.A. DE C.V. el 2023-7-18.
Para poder utilizarlo en un sistema de red interno, deberá disponer de la correspondiente licencia de AENOR